ACME CORPORATION - IT SECURITY AND DATA PROTECTION POLICY (POL-SEC-2

Page 1

1. PASSWORD MANAGEMENT AND ACCESS CONTROL

All employees, contractors, and partners must adhere to Acme Corporation's password and authentication guidelines.

Passwords must be a minimum of 14 characters in length and must include at least one uppercase letter, one lowercase letter, one number, and one special character (e.g., !@#$%^&*).

Passwords must be changed every 90 days, and the system prohibits the reuse of the previous 6 passwords.

Multi-Factor Authentication (MFA) is strictly mandatory for all corporate systems, including Google Workspace, VPN, and GitHub.

Approved MFA methods are FIDO2 hardware security keys (YubiKey) or time-based one-time password (TOTP) apps (Google Authenticator, Microsoft Authenticator).

SMS-based OTP is prohibited for authentication due to SIM-swapping risks.

ACME CORPORATION - IT SECURITY AND DATA PROTECTION POLICY (POL-SEC-2

Page 2

2. ENDPOINT SECURITY AND CLEAN DESK POLICY

All corporate-issued laptops must run company-managed endpoint detection and response (EDR) software and maintain BitLocker (Windows) or FileVault (macOS) full-disk encryption at all times.

Screen lock timeout is enforced centrally: all workstations must automatically lock after 5 minutes of inactivity.

Employees are required to lock their screens immediately (Windows Key + L or Cmd + Ctrl + Q) whenever stepping away from their desk.

Physical paper documents containing Personally Identifiable Information (PII) or sensitive corporate financials must be stored in locked drawers when unattended.

External storage devices: Connecting unauthorized USB flash drives or external hard drives to corporate laptops is strictly blocked by endpoint policy. Any business exception requires written authorization from the Chief Information Security Officer (CISO).

ACME CORPORATION - IT SECURITY AND DATA PROTECTION POLICY (POL-SEC-2

Page 3

3. INCIDENT REPORTING AND SECURE REMOTE ACCESS

Any suspected security incident, including phishing emails, lost or stolen devices, unauthorized access attempts, or ransomware indicators, must be reported to the Security Operations Center (SOC) within 30 minutes of discovery.

Incident reports must be sent directly to soc@acme.com or logged via the urgent hotline at extension 9110.

Remote access to internal company networks and development environments is permitted only through the corporate WireGuard VPN tunnel.

Split tunneling on the VPN client is strictly prohibited to prevent data leakage.

Public Wi-Fi networks (such as in airports, cafes, or hotels) must never be used without an active corporate VPN connection.

Employees traveling to high-risk foreign countries must travel with loaner travel laptops provided by IT and return them for forensic wiping immediately upon return.